

08

BOOK 08 / 08

코드를 보안 관점에서 읽기

하나의 기능을 끝까지 검토하기

개념 이해 / 사례 읽기 / 확인 문제 약 20분

비공개 학습 노트 서비스를 따라 배우는 보안의 기본

이 책을 읽는 방법

수정 근거와 정상·거부 사례를 함께 남깁니다.



읽기 순서

학습 목표와 선수 지식	3
시작 상황: 노트 조회 기능 검토 요청	3
검토할 의사코드	3
혼자 해 보기	4
해설: 줄 번호보다 데이터 흐름을 보기	5
개선한 의사코드	5
무엇을 검사할까?	6
최종 확인 문제	7
정답과 해설	8
핵심 요약과 다음 과정	8

사례를 먼저 읽고, 개념과 코드의 차이를 확인한 뒤 문제를 풀어 보세요. 정답과 해설은 문제 다음 페이지에서 시작합니다.

공통 사례 / 비공개 학습 노트

민서(사용자 101)의 노트는 10번, 준호(202)의 노트는 20번입니다. 모든 노트는 비공개이며, 로그인한 소유자만 조회·수정할 수 있습니다. 제목은 1~80자의 일반 텍스트입니다.

비밀번호·세션 토큰은 로그에 남기지 않고, 권한을 확인할 수 없으면 본문을 보내지 않습니다. 이 가상 서비스의 예제는 학습용 축약본이며 실제 서비스의 계정·데이터 구현과 무관합니다.

학습 목표와 선수 지식

1~7단원을 이해했다고 가정합니다. 학습 후에는 입력·신원·권한·처리·출력·실패 경로를 따라 읽고, 발견사항을 근거와 함께 기록하며, 수정 결과를 확인할 검사를 제안할 수 있습니다.

시작 상황: 노트 조회 기능 검토 요청

동료가 노트 상세 조회 기능을 만들었습니다. 정상적으로 내 노트가 표시되는 것은 확인했지만 다른 조건에서는 확인하지 않았습니다. 아래 흐름에서 어떤 질문을 해야 할까요?

검토할 의사코드

다음은 여러 개념을 함께 찾는 종합 예제입니다. 실행 가능한 코드가 아닙니다. 제목은 일반 텍스트이며, 인증 처리와 `escape_html_text`는 구현되어 있다고 가정합니다.

PSEUDOCODE / 흐름 읽기

```
01 current_user = 검증된 세션에서 사용자 찾기(요청.쿠키)
02 current_user가 없으면 로그인 필요 응답 후 종료
03 note_id = 요청.경로의_노트번호
04 note_id가 허용된 양의 정수 형식인지 검사, 실패하면 종료
05 note = DB에서_매개변수로_노트_조회(note_id)
06 note가 없으면 찾을 수 없음 응답 후 종료
07 로그에 기록(요청 추적 ID, 요청.쿠키 전체, note.본문)
08 HTML = "<h1>" + note.제목 + "</h1>"
09 HTML에 escape_html_text(note.본문)을 덧붙인다
10 HTML을 응답한다
```

혼자 해 보기

1. 외부 입력과 서버가 확인한 정보를 각각 표시하세요.

2. 보호 정책에 어긋나는 지점을 세 가지 찾으세요.

3. 각 지점에 '원인 → 가능한 영향 → 수정 방향'을 한 문장씩 적으세요.

4. 수정 이후 확인할 정상 사례와 거부 사례를 적으세요.

해설: 줄 번호보다 데이터 흐름을 보기

관찰	판단 근거	수정 방향
01~02행에서 로그인 확인	사용자 신원은 확인하지만 노트 소유 여부는 아직 모름	05행의 조회 조건에 현재 사용자 소유 조건을 포함하거나 반환 전 인가 검사
05행에서 번호만으로 조회	번호 형식과 SQL 매개변수화는 소유권을 확인하지 않음	다른 사용자의 노트가 응답으로 이어지지 않도록 제한
07행에서 쿠키 전체와 본문 기록	세션 토큰과 비공개 정보가 별도 저장 위치로 복제됨	사건·결과·추적 ID 중심으로 기록하고 민감 정보 제외
08행에서 제목을 HTML에 직접 결합	일반 텍스트 제목이 HTML 문법으로 해석될 수 있음	HTML 본문 위치에 맞는 텍스트 인코딩 적용
09행에서 본문만 인코딩	한 필드의 보호가 다른 필드에 자동 적용되지 않음	출력되는 필드마다 위치와 처리 방법 확인

주요 수정 대상은 인가 누락, 민감정보 로깅, 제목 출력 처리입니다. 마지막 두 행은 같은 출력 문제의 범위를 설명합니다. 이 흐름에 오류 처리 방식이 적혀 있지 않으므로 'DB 오류 때 허용한다'고 단정해서는 안 됩니다. 누락된 실패 정책은 추가로 확인할 항목입니다.

개선한 의사코드

PSEUDOCODE / 흐름 읽기

현재 사용자 = 검증된 세션에서 확인한다
 현재 사용자가 없으면 본문 없이 종료한다
 노트 번호가 허용된 양의 정수 형식인지 검사한다

시도:

노트 = 현재 사용자 소유 조건과 노트 번호를 매개변수로 조회한다

DB 장애가 발생하면:

민감정보를 제외한 오류 유형과 요청 추적 ID를 기록한다
 본문 없이 일시적 처리 실패를 응답하고 종료한다

노트가 없으면:

본문 없이 찾을 수 없음으로 응답하고 종료한다

사건 종류, 결과, 요청 추적 ID를 기록한다

제목과 본문을 HTML 텍스트 위치에 맞게 인코딩하여 응답한다

이 예제는 비소유 노트와 존재하지 않는 노트에 같은 외부 응답을 사용합니다. 자원 존재 여부를 노출하지 않으려는 선택입니다. 이 응답 정책만으로 시간 차이 등 모든 정보 노출 가능성까지 제거했다고 할 수는 없습니다.

무엇을 검사할까?

상황	기대 결과	확인하는 목적
민서가 10번 조회	민서 노트가 정상 표시됨	정상 기능 보존
민서가 20번 조회	준호 본문이 반환되지 않음	소유자별 인가
로그인 없이 조회	비공개 본문이 반환되지 않음	인증 전 접근 제한
존재하지 않는 번호 조회	본문 없이 정해진 응답	누락 자원 처리
음수·문자·범위 초과 번호	정책에 따라 거부, 조회하지 않음	입력 형식·범위 검사
제목이 중요	제목 문자열 그대로 표시됨	HTML 본문 출력 처리
제목에 작은따옴표 포함	원래 제목이 유지됨	정상 데이터 보존
DB 조회 중 장애	성공 응답이나 비공개 본문을 보내지 않음	실패 시 보호 조건
조회 성공·실패 기록 확인	쿠키·토큰·비공개 본문이 기록되지 않음	로그의 정보 최소화

한 검사만으로 전체 안전성을 판정하지 않습니다. 여기서는 조회 기능을 살폈으므로 수정·삭제·파일 첨부·공유 기능은 별도 범위입니다. 또한 로그인 구현, 세션 저장소, 운영 DB 권한 등 의사코드에서 가정한 요소도 실제 서비스에서는 검토해야 합니다.

최종 확인 문제

1. '입력은 숫자이고 SQL 매개변수도 사용했다'는 설명만으로 인가 검사를 생략할 수 없는 이유를 적으세요.

2. 수정 후 모든 노트 요청이 거부됩니다. 다른 사람의 노트 접근이 막혔으니 수정 완료일까요?

3. 검토한 코드에 장애 처리 내용이 없을 때, 확인된 결함과 추가 확인사항을 어떻게 구분해 적을까요?

정답과 해설

1. 형식 검사와 SQL 데이터 분리는 요청자에게 그 노트를 읽을 권한이 있는지 판단하지 않습니다.
2. 아닙니다. 소유자의 정상 접근도 유지해야 합니다. 보호 조건과 기능 요구사항을 함께 만족해야 합니다.
3. 보이는 근거로 확인한 인가 누락 등은 결함으로 적고, 장애 시 허용 여부처럼 구현을 보지 못한 내용은 확인 필요로 기록합니다.

핵심 요약과 다음 과정

코드를 읽을 때 **출처 → 신원 → 권한 → 사용 위치 → 출력 → 실패 경로**를 따라가세요. 발견사항에는 원인과 영향, 수정 방향과 확인 방법을 남기세요. '안전해졌다'는 말 대신 무엇을 확인했고 무엇이 남았는지 설명하세요.

다음 OWASP Top 10:2025 과정에서는 이런 문제들이 어떤 위험 범주에 속하는지 큰 그림을 봅니다. 이어지는 보안약점 과정에서는 SQL 삽입, 부적절한 인가, 오류 메시지 정보노출 등 개별 원인과 언어별 대응을 깊이 다룹니다.

종합 사례와 확인 문제는 이 과정을 위해 새로 작성했습니다. 원칙별 출처는 3~7단원에 있으며, 후속 과정의 판본은 [OWASP Top 10 공식 프로젝트](#)를 기준으로 합니다.

나의 한 문장

이 강의에서 배운 내용을 동료에게 설명한다면 어떻게 말할까요?